

SecCheck

종합 기술 매뉴얼

기능·화면, API·MCP, 아키텍처를 한 권으로

버전 v1.0.146

작성일 2026-09-18

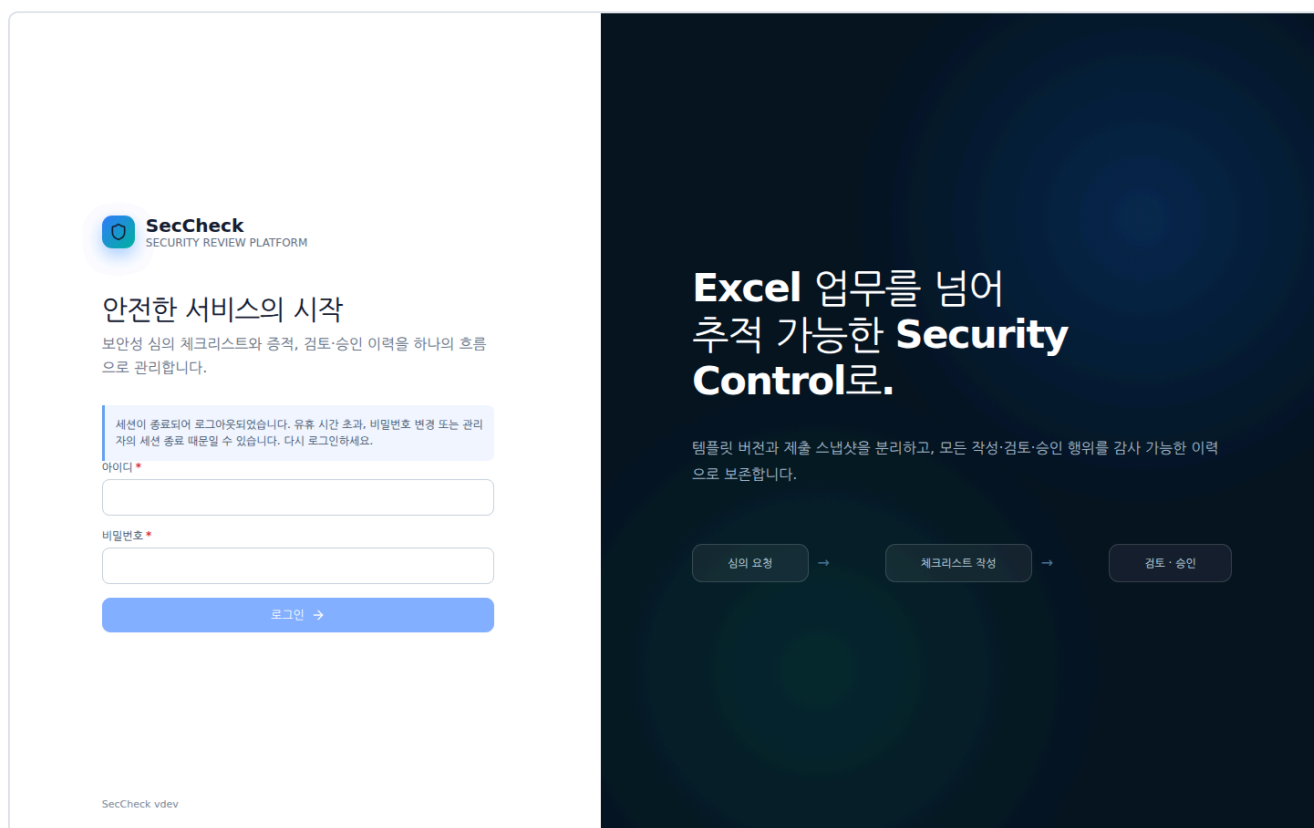
문서 종합 기술 매뉴얼

SecCheck 기능 및 화면 가이드 (Features & UI Guide)

SecCheck 는 Excel 기반 보안성 심의 업무를 템플릿·버전·제출 스냅샷·항목별 검토로 체계화한 **엔터프라이즈 오프라인 운영형 보안 검토 플랫폼**입니다.

전체 메뉴별 주요 화면 및 기능 명세

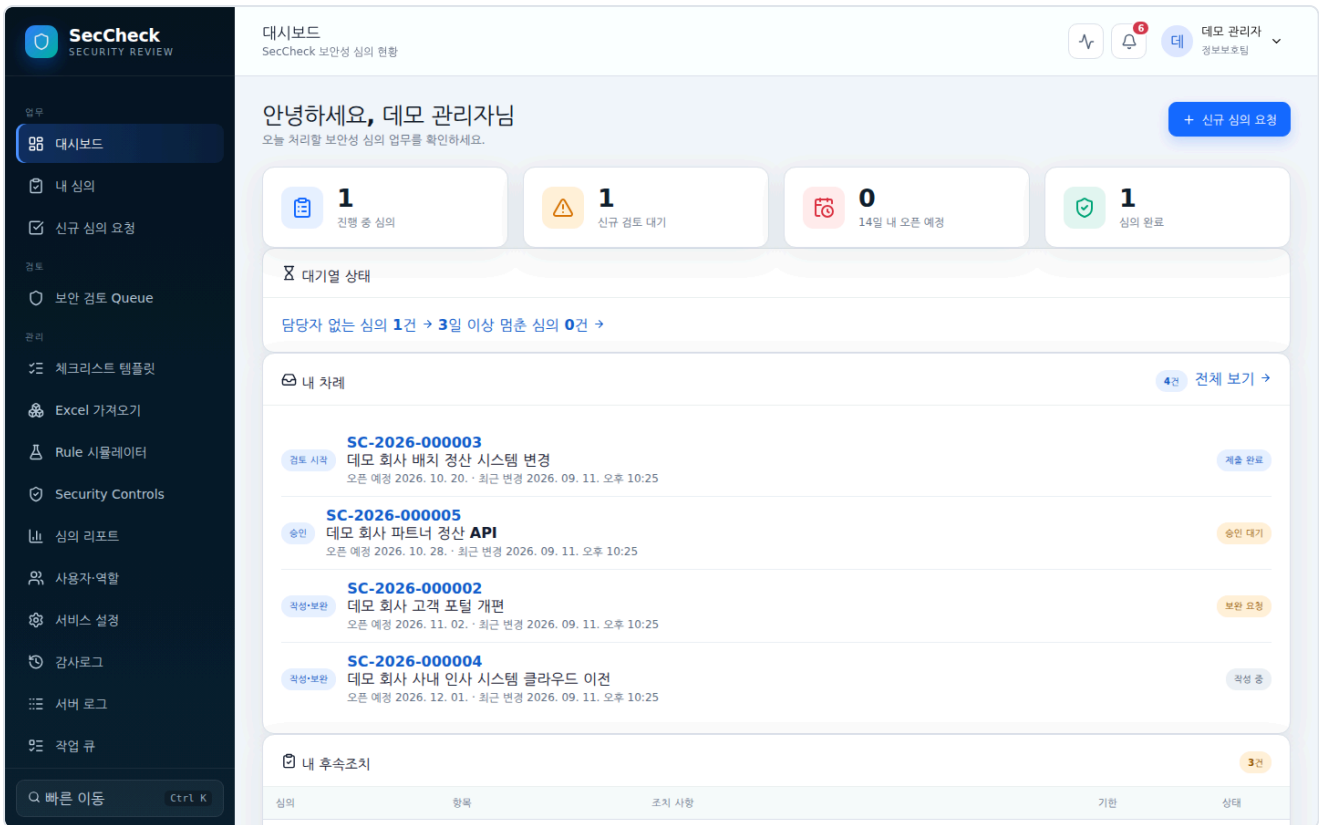
1. 인증 및 로그인 (/login)



로그인 화면

- 로컬 부트스트랩 관리자: 초기 4대 환경변수(`BOOTSTRAP_ADMIN` , `BOOTSTRAP_ADMIN_PASSWORD`) 기반 보안 로그인
- Keycloak OIDC SSO: 설정 시 사내 SSO로 로그인 버튼을 통한 통합 인증 연동
- 서비스 브랜드 & 버전: 현재 릴리스 버전(`v0.1.0`) 및 서비스명 실시간 표시

2. 보안 심의 대시보드 (/ , /dashboard)



대시보드

- **내 후속조치:** 이행해야 할 후속조치를 심의 전체에서 모아 표시. 기한 초과와 확인 대기 상태를 구분하며, 리포트를 열 수 없는 요청자도 자기 조치 목록을 확인 가능
- **내 담당 항목:** 나에게 배정된 체크리스트 항목을 심의를 가로질러 모아 심의별 배정·미작성·보완 필요 건수로 표시. 심의번호를 누르면 그 심의가 **내 담당 항목** 필터가 켜진 상태로 열립니다. 남은 작업이 없는 심의는 목록에서 사라집니다
- **핵심 KPI 현황 카드:** 진행 중 심의(Active), 신규 검토 대기/미처리 보완 요청(Pending), 14일 내 오픈 예정, 심의 완료 통계 오픈 예정 카드에는 그중 **심의가 끝나지 않은 건수**가 함께 표시되어, 검토가 완료되지 않은 채 열릴 서비스가 몇 건인지 바로 보입니다. **각 카드를 누르면 그 숫자에 해당하는 심의 목록**이 열립니다.
- **대시보드의 범위 = 목록의 범위:** 카드의 숫자는 모두 그 숫자에 해당하는 심의 목록을 여는 링크이므로, 세는 범위와 열 수 있는 범위를 같은 규칙으로 맞춥니다. 전체 심의를 보는 것은 보안 담당자·감사이고, 시스템 관리자(그 역할만 가진 경우)의 대시보드는 본인 업무를 보여 줍니다. 조직 전체 현황은 리포트에서 봅니다
- **대기열 상태**(보안 담당자·감사): 담당자가 없는 심의와 3일 이상 멈춘 심의 수를 보여 주고 같은 조건의 목록으로 연결합니다. 팀이 조치를 마쳐 **확인만 남은 보완 요청** 건수도 함께 표시합니다(기한과 무관하게, 확인해 줘야 심의가 끝나는 일이기 때문입니다). 정체 판정 기준(기간과 상태)은 심의 정체 알림과 한 곳에서 공유하므로 화면의 숫자와 메일이 어긋나지 않습니다.
- **최근 심의 테이블:** 최근 요청된 심의의 심의번호, 서비스명, 상태, 오픈 예정일 요약
- **업무 흐름 가이드:** 서비스 정보 입력 → 체크리스트 작성·증적 → 검토·보완·재제출 → 승인·결과 보존 4단계 Snapshot 프로세스 안내

3. 보안성 심의 목록 (/reviews)

SecCheck
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자 역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

심의 관리
작성·제출·보완 상태를 관리합니다

심의 목록
권한이 있는 심의 건만 표시됩니다.

CSV + 신규 심의

Q 심의번호, 서비스명, 부서 검색

전체 상태

최근 변경순

조건부 승인 내 차례 기한 초과 담당자 없음 정제 오픈 임박

담당 부서 보안 담당자 생성일 시작 생성일 종료

mm/dd/yyyy mm/dd/yyyy

심의번호	서비스	유형	담당 부서	요청자 / 검토자	보완	오픈 예정	상태
SC-2026-000006	데모 회사 협력사 파일 전송 게이트웨이	EXTERNAL · NEW	구매지원팀	데모 관리자 데모 관리자	-	2026. 10. 15.	반려 반려 상 세
SC-2026-000005	데모 회사 파트너 경산 API	EXTERNAL · NEW	계류사업팀	데모 관리자 데모 관리자	-	2026. 10. 28.	승인 대기 조건부 상 세
SC-2026-000001	데모 회사 모바일 앱 푸시 서버	INTERNAL · NEW	모바일플랫폼팀	데모 관리자 데모 관리자	-	2026. 10. 05.	심의 완료 상 세
SC-2026-000002	데모 회사 고객 포털 개편	EXTERNAL · NEW	플랫폼개발팀	데모 관리자 데모 관리자	1건	2026. 11. 02.	보완 요청 상 세
SC-2026-000003	데모 회사 배치 경산 시스템 변경	BATCH · CHANGE	경산운영팀	데모 관리자 미배정	-	2026. 10. 20.	제출 완료 상 세
SC-2026-000004	데모 회사 사내 인사 시스템 클라우드 이전	INTERNAL · CHANGE	인사기획팀	데모 관리자 미배정	-	2026. 12. 01.	작성 중 상 세

심의 목록

- 다차원 실시간 검색 & 필터링: 심의번호, 서비스명, 담당 부서 키워드 검색 및 상태 필터(작성 중, 제출 완료, 재제출, 검토 중, 보완 요청, 승인 대기, 심의 완료, 반려)
- 신규 심의 요청: 상단 신규 심의 버튼을 통한 즉시 요청 생성

4. 신규 보안성 심의 요청 (/reviews/new)

신규 보안성 심의 요청

서비스 특성을 정확히 입력하면 Rule Engine이 게시된 템플릿에서 항목을 스캔해서 배정합니다.

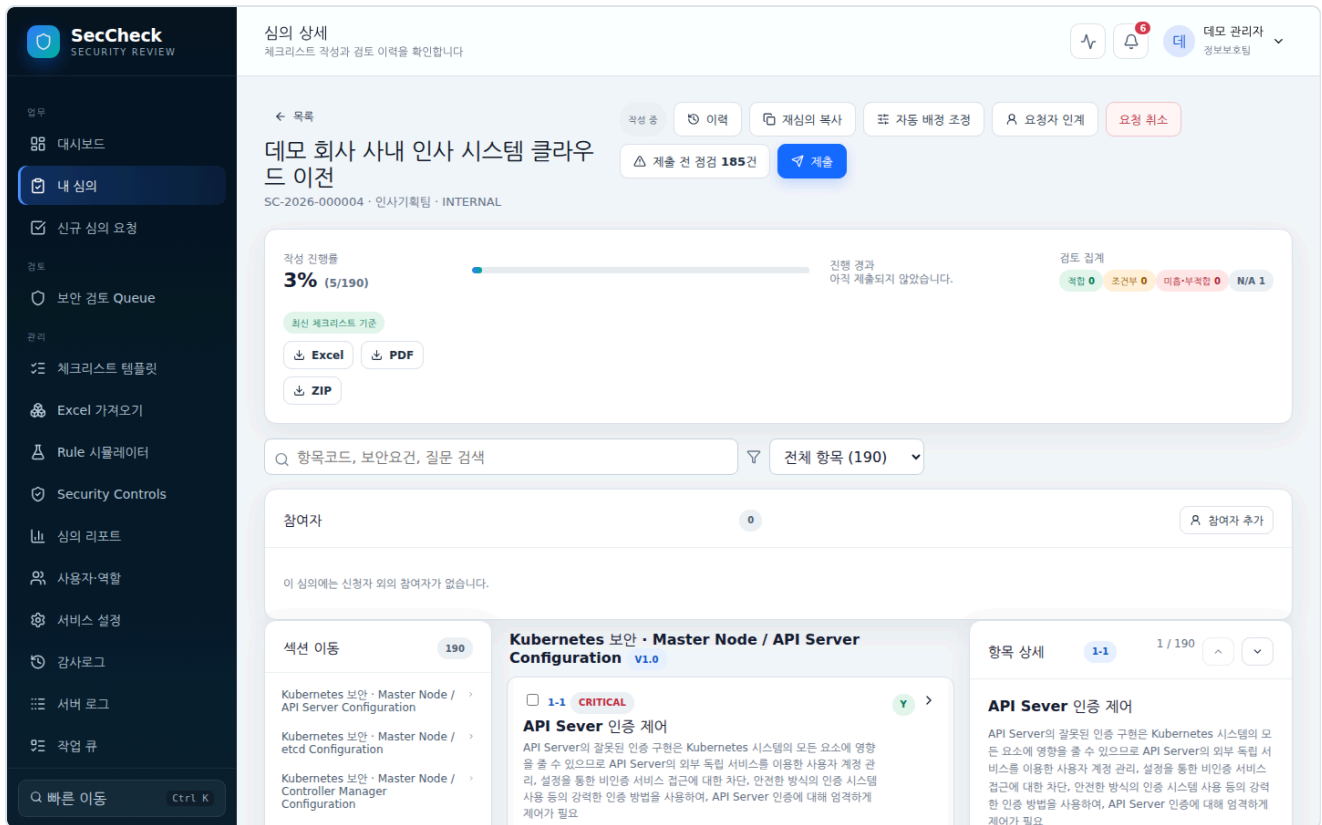
← 돌아가기

서비스 기본정보	
서비스명 * 서비스 설명 * 	담당 부서 * 정보보호팀
서비스 유형 * 대내 서비스 ▼	신규·변경 구분 * 신규 ▼
구축 담당자 * 데모 관리자 · 정보보호팀 ▼	개발 담당자 * 데모 관리자 · 정보보호팀 ▼
운영 담당자 선택 안 함 ▼	오른 예정일 mm/dd/yyyy □
대내+대의 여부 * 대내 ▼	업무 중요도 보통 ▼

적용 조건

관리자 페이지 존재
☐
개인정보 처리
☒

- **서비스 기본정보:** 서비스명, 담당 부서, 서비스 설명, 서비스 유형(대내/대외/관리자/배치), 신규·변경 구분, 구축·개발·운영 담당자, 오픈 예정일, 업무 중요도
- **Rule Engine 적용 조건:**
 - 관리자 페이지 존재, 개인정보 처리, 개인신용정보 처리, 외부 고객 서비스, 클라우드 사용, Docker 사용, Kubernetes 사용, 외부기관 연계, 인터넷 통신 여부
- **지능형 스냅샷 자동 배정:** 품 제출 즉시 Rule Engine이 조건에 부합하는 게시 템플릿의 항목들을 불변 스냅샷으로 배정



심의 상세 및 체크리스트

- **작성 진행률 & 검토 집계 바:** 총 항목 대비 작성률(%), 적합/조건부/미흡/N/A 집계 실시간 표시
- **빈 화면과 실패한 화면의 구분:** 목록을 불러오지 못하면 빈 목록이나 무한 로딩이 아니라 화면을 불러오지 못했습니다 와 원인, 다시 시도 버튼을 보여 줍니다
- **검색 결과 안내:** 통합 검색은 종류별 20건까지 보여 주고, 더 있으면 "더 많은 결과가 있습니다"를 함께 표시해 찾는 대상이 목록 밖에 있을 수 있음을 알립니다
- **대시보드 카드 상한 안내:** 내 차례 · 보완 조치 기한 · 내 후속조치 · 내 담당 항목 은 12건까지 표시하며, 더 있으면 12건만 표시 라고 밝힙니다
- **검색 대상:** 심의번호·서비스명·부서·템플릿명과 함께 신청자·구축·개발·운영 담당자·검토자·승인자의 이름으로 찾습니다. 항목은 항목코드·보안요건·질문뿐 아니라 작성자가 쓴 답변(현재 상태·조치 계획·N/A 사유)과 검토 의견 본문까지 찾습니다. 어디에서 걸렸는지(답변 / 검토 의견)와 해당 문장을 결과 줄에 함께 보여 주고, 항목 결과를 누르면 그 항목이 펼쳐진 채로 심의가 열립니다. 볼 수 있는 심의의 내용만 검색됩니다.
- **접근성:** 저장·실패 알림(토스트)과 로딩 표시가 보조기술에 전달됩니다(`aria-live` , `role`). 대화 상자는 열릴 때 포커스를 가져가고 Tab이 그 안에서만 순환하며 닫으면 원래 위치로 포커스를 돌려줍니다(`role="dialog"` , `aria-modal`). 모든 입력 항목의 라벨이 해당 컨트롤에 연결되어 있어 화면 낭독기가 이름을 읽고 라벨 클릭으로 포커스가 이동합니다. 도움말과 오류 문구도 컨트롤에 연결되어 함께 읽힙니다 체크리스트 항목은 행 오른쪽의 펼침 버튼으로 키보드에서도 열고 닫을 수 있으며(`aria-expanded`), 항목 편집기는 키보드로 이동만 해도 현재 항목으로 인식합니다.
- **오픈 임박 필터:** 오픈 예정일이 2주 이내인데 아직 끝나지 않은 심의만 추려 봅니다. 대시보드의 미완료 N건 을 누를 때 보게 되는 목록과 같은 조건입니다
- **최종 결과 표시·필터:** 목록 행에 승인/조건부/반려를 함께 표시하고 조건부 승인 칩으로 걸러 봅니다. `result=` 파라미터로 여러 결과를 한 번에 지정할 수 있습니다

- **담당자 없음·정체 필터:** 대시보드의 대기열 상태 숫자와 같은 조건으로 목록을 걸러 봅니다. 숫자를 누르면 그 심의들만 남습니다.
- **1클릭 다중 포맷 내보내기:** Excel (.xlsx), PDF (.pdf), ZIP 결과물 즉시 다운로드
- **보존되는 기록의 범위:** Excel과 JSON에는 항목·답변·판정·증적 목록(파일명과 SHA-256)에 더해 **보완 요청 이력**(요청 사유·요청자·담당자·기한·상태·조치 내용)이 포함됩니다. 심의가 몇 번 오갔는지는 결론만큼이나 기록의 일부입니다
- **약속까지 포함한 결과물:** 항목별 판정과 함께 후속조치 내용·조치 기한·이행 보고일·이행 확인일이 JSON·Excel·PDF에 모두 실립니다. 조건부 적합의 조건이 결과물에서 빠지면 나중에 확인할 방법이 없습니다
- **섹션 네비게이션 & 항목 필터:** 템플릿/섹션별 빠른 이동 및 미작성, N/A, 증적 누락, 보완 요청, 코멘트 있음, 지적 항목(미흡·부적합·조건부·재확인) 필터, 판정 이후 답변이 바뀐 항목 필터. 필터 조건은 서버가 제출·완료 가드와 같은 규칙으로 판정해 내려줍니다
- **선택 항목 일괄 판정(검토자):** 반복되는 판정을 한 번에 적용. 이미 판정한 항목은 건너뛰며 덮어쓰기 선택 시에만 교체. 최대 1000개, 검토 중(REVIEWING) 상태의 배정된 검토자만 가능
- **선택 항목 일괄 보완 요청(검토자):** 같은 사유·기한·담당자로 여러 항목에 보완을 한 번에 요청합니다. 중복 요청은 건너뛰고 알림은 한 번만 발송합니다.
- **이월 답변 표시:** 재심의로 복사된 답변은 다시 저장하기 전까지 이월 답변 으로 표시되고 필터로 모아 볼 수 있습니다. 정기 심의가 작년 답변을 그대로 통과시키는 것을 막습니다.
- **판정 이후 답변·증적이 바뀐 항목 감지:** 보완 요청은 심의 전체를 작성자에게 돌려보내므로 요청하지 않은 항목까지 수정될 수 있습니다. 판정보다 답변이나 증적(추가·새 버전·삭제)이 나중에 바뀐 항목은 검토 후 답변 변경 뱃지로 표시하고, 남아 있는 동안에는 검토 완료를 거부하며 몇 건이 남았는지 알려 줍니다. 판정은 자기가 판정한 답변·증적보다 이른 시각으로 기록되지 않으므로, 서버 시계가 뒤로 물러나도 재판정이 항상 지적을 해소합니다.
- **진행 경과:** 제출일·최종 제출일·승인일을 심의 상단에 표시. 화면에서 심의가 언제 이루어졌는지 확인 가능(기존에는 내보낸 파일에만 존재)
- **증적 업로더 표시:** 증적마다 첨부한 사람을 함께 표시해 여러 명이 작성하는 심의에서 책임 소재를 확인
- **다른 서비스의 판정:** 같은 항목 코드가 다른 서비스에서 어떻게 판정됐는지 최근 5건을 함께 보여 줍니다(보안 담당자·감사 전용). 같은 통제에 대한 판정 기준이 서비스마다 갈리는 것을 한 화면에서 확인
- **배정 이유 설명:** 항목마다 이 서비스의 특성 중 무엇이 적용 조건을 만족시켰는지(또는 수동 포함 사유가 무엇인지) 조건별로 보여 줍니다
- **이전 심의 증적 가져오기:** 같은 서비스의 지난 심의에 첨부된 증적을 항목 단위로 이 심의에 복사. 항목의 증적 첨부 영역에서 가져올 수 있는 파일이 있으면 먼저 알려 줍니다(이전 심의의 판정 여부와 무관). 파일은 원본 키로 복호화해 가져오는 사람의 키로 다시 암호화하며(증적 1건 = 키 1개 원칙 유지), 해시를 비교해 동일한 파일인지 확인합니다. 검사를 통과하지 않은 파일은 제외
- **이 서비스의 지난 심의:** 같은 서비스의 이전 심의를 상태·최종 결과·그때의 지적 건수와 함께 표에 모아 보여 줍니다(이름을 바꿔도 이어집니다)
- **결재 전 확인(승인 대기):** 지적 항목과 검토 의견, 승인 시 남는 후속조치와 기한, 미검증 보완 요청 수를 결재 버튼 위에 모아 표시. 기한 없는 후속조치는 별도 경고
- **심의 결론:** 최종 결과·최종 의견과 승인자의 결재 코멘트·일시를 심의 상단에 표시. 반려 사유를 요청자가 화면에서 바로 확인
- **제출 후 심의 취소:** 서비스 계획이 접히면 결정 전 어느 단계에서든 요청자가 사유와 함께 취소하고, 검토자·승인자에게 즉시 알립니다

- **반려 심의 보완 재개:** 반려된 심의를 담당 보안 담당자가 보완 필요 상태로 되돌려 같은 심의번호로 이어서 보완·재제출할 수 있게 합니다. 철회된 최종 결과는 지우고 반려 결정 이력은 남깁니다
- **결재 요청 회수:** 승인 대기 중인 심의를 담당 보안 담당자가 검토 중 으로 되돌려 판정과 최종 의견을 다시 작성합니다. 승인자에게 회수 사유가 전달됩니다
- **두 번째 눈 보장:** 심의를 검토·판정한 사람은 같은 심의를 최종 승인할 수 없습니다. 그 심의는 다른 승인자에게 열리며, 1인 운영 설정을 켜 경우에만 예외입니다
- **담당자 지정 검증:** 검토자·승인자 칸에는 해당 역할을 가진 활성 계정만 넣을 수 있고, 같은 사람을 두 칸에 넣거나 신청자를 넣는 조합은 지정 시점에 거절합니다
- **검토 결과 열람:** 검토가 끝난 항목은 판정·검토 의견·후속조치·기한·이행 여부를 읽기 전용으로 표시. 편집 권한이 없는 참여자도 무엇이 왜 그렇게 판정되었는지 확인 가능
- **항목 순차 이동:** 항목 상세 의 위·아래 버튼 또는 Alt + ↑ / ↓ 로 다음·이전 항목 이동. 현재 필터가 적용된 목록 순서를 따르며 34 / 134 처럼 위치를 표시. 답변 입력 중에도 동작

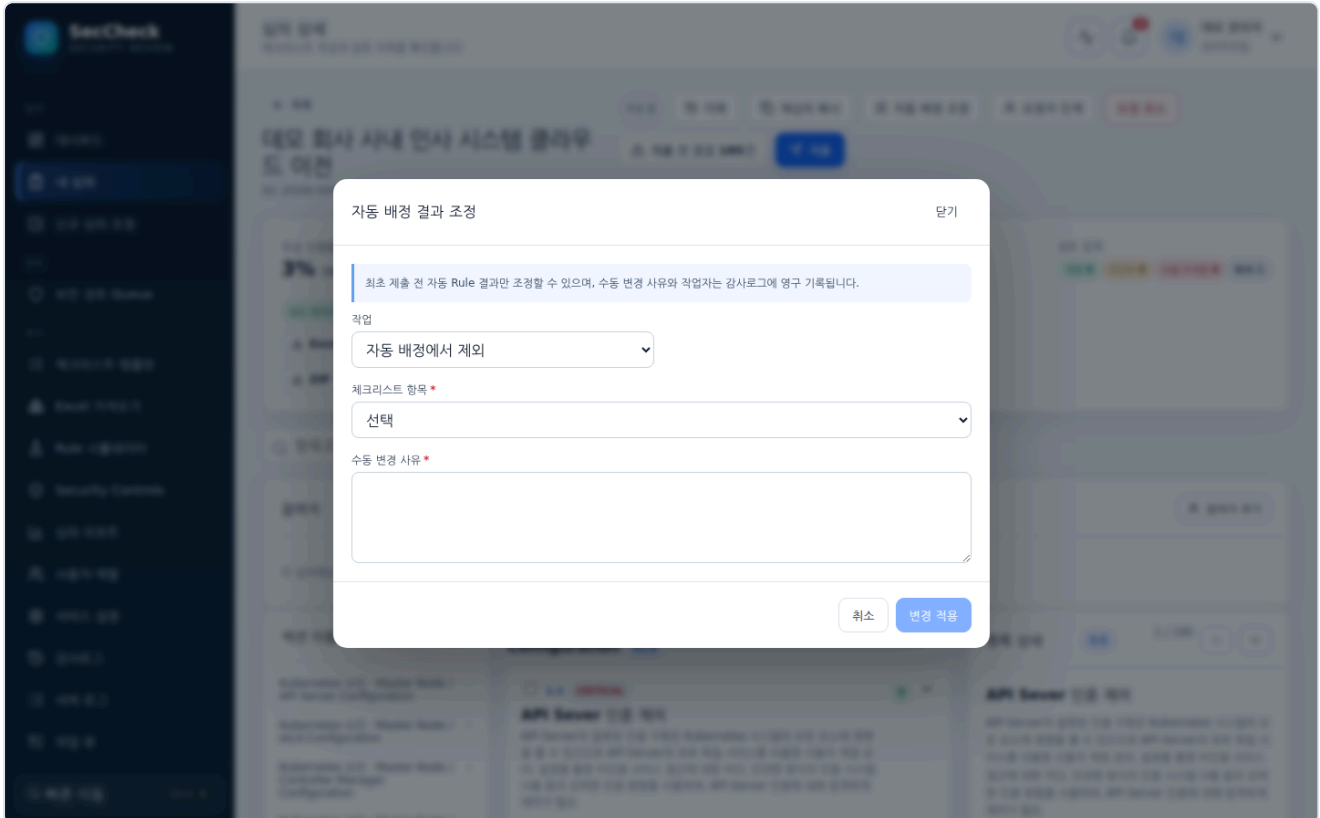
6. 체크리스트 항목 편집 & 증적 암호화 업로드

항목 편집기

- **적용 여부 & 자체 판단:** Y, N, N/A 원클릭 선택 및 적합/미흡 자체 평가
- **N/A 사유 & 현황 작성:** N/A 선택 시 필수 사유 입력 및 조치 계획 수립
- **실시간 자동 저장:** 타이핑 시 수초 내 백그라운드 자동 저장 및 상태 알림

- **증적 여러 건 동시 선택:** 파일 선택 시 여러 개를 한 번에 지정. 각각 별도 증적으로 저장되며, 일부가 정책에 걸려 실패해도 나머지는 그대로 저장됨 파일 선택창은 **허용 확장자만** 보여 주며, 최대 크기를 넘는 파일은 전송을 시작하기 전에 이유와 함께 거절합니다.
- **증적 첨부 (AES-256-GCM):** 증적 파일 업로드 시 Magic/MIME 검증, SHA-256 해시 생성, 개인 데이터 키 버전 기반 AES-256-GCM 암호화 보관

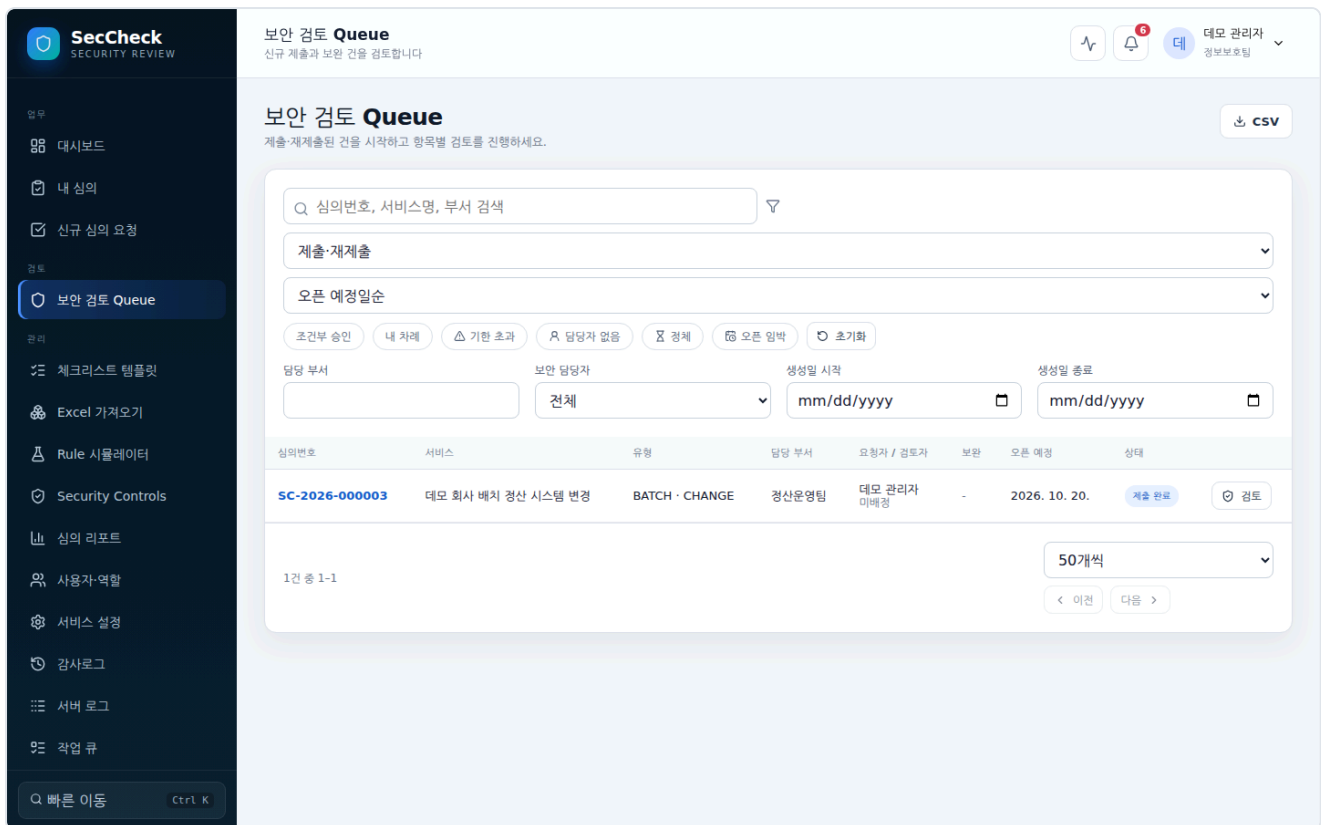
7. 자동 배정 결과 수동 조정 (Rule Override)



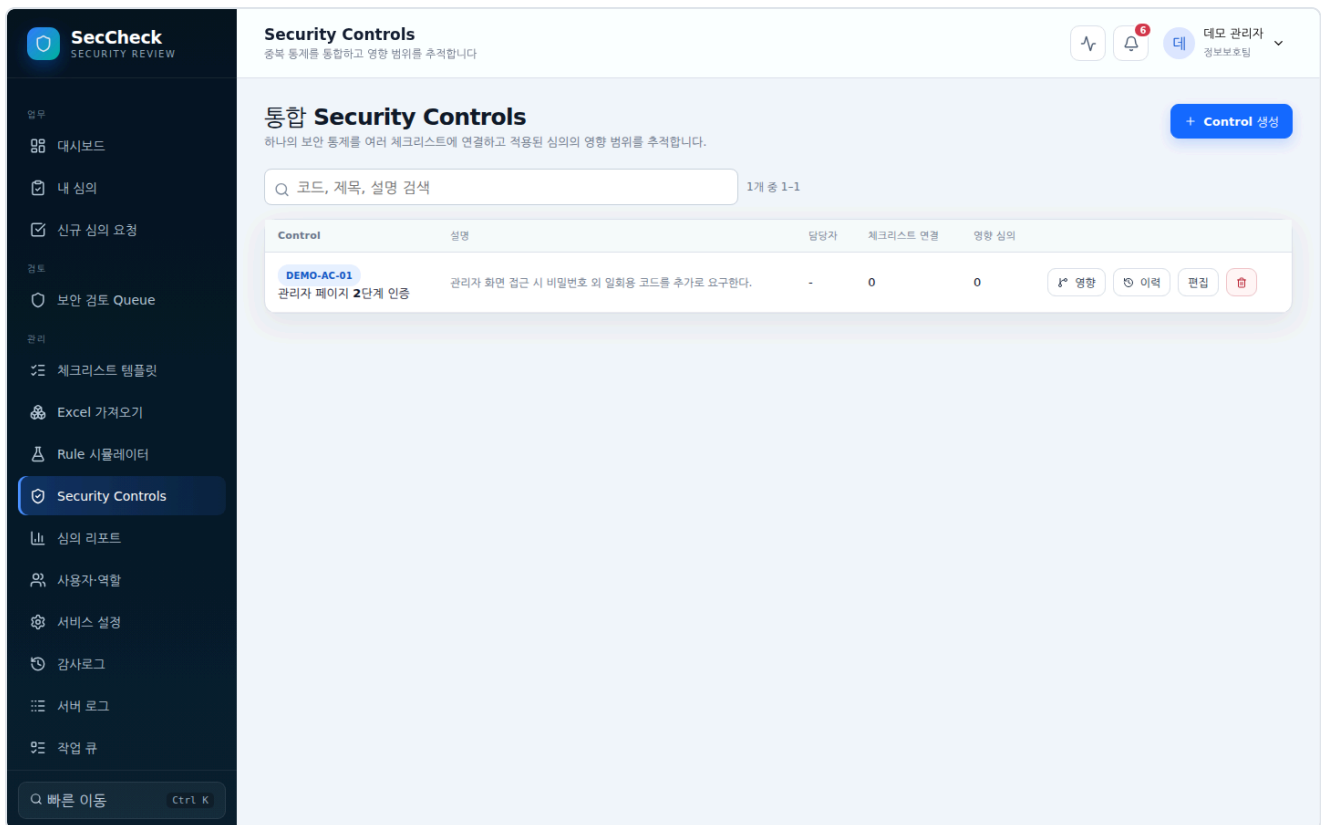
자동 배정 조정 모달

- **규칙 예외 처리:** 서비스 특성에 따라 자동 배정된 항목을 제외하거나 미배정 항목을 수동 포함
- **불변 감사 추적:** 수동 변경 사유, 작업자, 시각을 감사로그에 영구 기록

8. 보안 검토 Queue (/security)



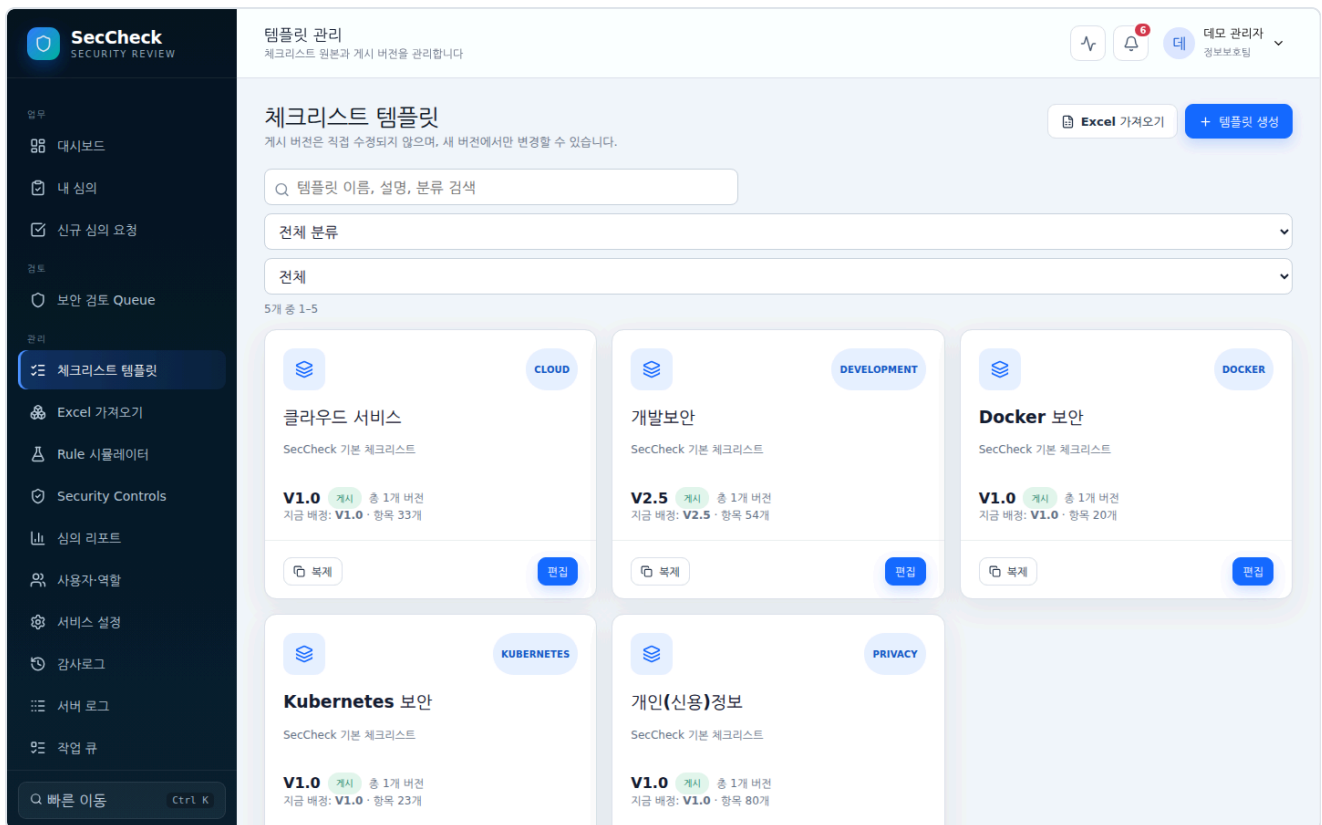
- **보안 담당자 전용 대기열:** 제출(SUBMITTED) 및 재제출(RESUBMITTED)된 심의 건을 집중 관리하고 검토 시작 및 항목별 검토 의견/보완 요청 등록



Security Controls

- **단일 보안 통제 관리:** SEC-ENC-001 등 표준 보안 통제 코드와 제목/설명 관리
- **영향 범위 (Blast Radius) 추적:** 해당 Control이 연결된 체크리스트 템플릿 및 적용된 심의 건수를 실시간 추적
- **판정 이력:** 이 Control로 연결된 항목들이 실제 심의에서 어떻게 판정됐는지(적합·조건부·미흡·부적합·N/A 건수)와 최근 지적 10건을 함께 보여 줍니다. 집계 기준이 항목 코드가 아니라 Control 연결이므로, 템플릿이 바뀌어 코드가 달라져도 한 통제의 이력으로 이어집니다

10. 체크리스트 템플릿 관리 (/templates)



체크리스트 템플릿 목록

- **기본 탑재 템플릿:** 개발보안, 개인(신용)정보보호, 클라우드 보안, Docker/Kubernetes 컨테이너 보안 템플릿 자동 시딩
- **버전 분리 원칙:** 게시된 버전은 수정 불가능하며, 새 버전 생성을 통해서만 안전하게 변경 관리
- **사용 중지:** 게시된 버전을 사용 중지 하면 이후 새 심의에 배정되지 않습니다. 이미 만들어진 심의의 스냅샷은 그대로 유지되므로, 진행 중인 심의에 영향을 주지 않고 낡은 체크리스트를 물러나게 할 수 있습니다

11. 템플릿 상세 및 카테고리/항목 편집 (/templates/:id)

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

템플릿 편집

초안 항목과 버전을 관리합니다

템플릿

클라우드 서비스

CLOUD · SecCheck 기본 체크리스트

V1.0 · PUBLISHED

개시

기본 체크리스트 자동 등록

변경 이력

항목코드, 섹션, 보안요건, 질문, 가이드 검색

전체 중요도

33 / 33개 항목

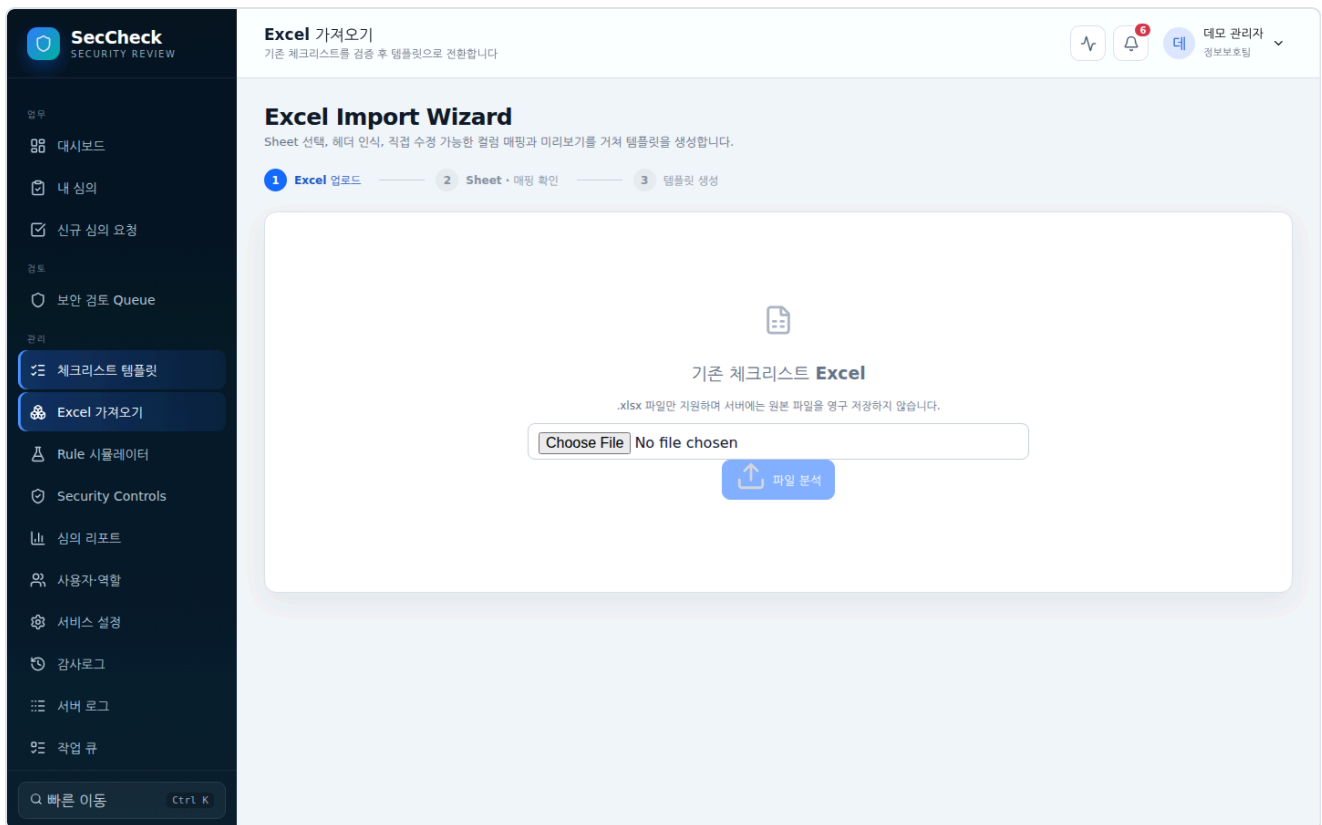
순서	코드	섹션	보안요건	중요도	입력 유형	필수
1	CLOUD-001	공통	바이러스, 웜, 트로이목마 등의 악성코드 탐지 및 차단 기술 적용하고 있는가? 바이러스, 웜, 트로이목마 등의 악성코드 탐지 및 차단 기술 적용하고 있는가?	MEDIUM	YNNA	필수
2	CLOUD-002	공통	가상환경에서 이상징후 발견 시 사용 중지 및 격리 체계 마련하고 있는가? 가상환경에서 이상징후 발견 시 사용 중지 및 격리 체계 마련하고 있는가?	MEDIUM	YNNA	필수
3	CLOUD-003	가상화보안	가상자원의 생성, 변경, 회수 등에 대한 관리방안 마련하고 있는가? 가상자원의 생성, 변경, 회수 등에 대한 관리방안 마련하고 있는가?	MEDIUM	YNNA	필수
4	CLOUD-004	가상화보안	가상자원에 대한 무결성 보장을 위한 보호조치 및 변경 내역 모니터링을 하고 있는가? 가상자원에 대한 무결성 보장을 위한 보호조치 및 변경 내역 모니터링을 하고 있는가?	MEDIUM	YNNA	필수
5	CLOUD-005	가상화보안	호스트OS 및 가상화관리 소프트웨어 모니터링 및 패치를 포함한 악성코드 방지대책 마련하고 있는가? 호스트OS 및 가상화관리 소프트웨어 모니터링 및 패치를 포함한 악성코드 방지대책 마련하고 있는가?	MEDIUM	YNNA	필수
6	CLOUD-006	가상화보안	가상화 실행 이력의 안전한 저장-관리 방안을 수립하고 있는가? 가상화 실행 이력의 안전한 저장-관리 방안을 수립하고 있는가?	MEDIUM	YNNA	필수
7	CLOUD-007	가상화보안	가상화 OS의 내/외부 데이터 이용에 대한 로그 관리를 하고 있는가? 가상화 OS의 내/외부 데이터 이용에 대한 로그 관리를 하고 있는가?	MEDIUM	YNNA	필수

하드웨어, 가상 이미지, 가상화 관리 소프트웨어(하이퍼바이저 등)에 대한 잠재적 위협을 고려하여 취약점

템플릿 상세

- **카테고리 & 항목 구성:** 보안 요건, 질문, 가이드, 작성 예시, 법적 근거, 가중치, 증적 필수 여부 정의
- **Rule Engine 조건 지정:** 특정 서비스 특성(개인정보, 클라우드, K8s 등)일 때만 자동 배정되도록 조건 규칙 설정

12. Excel Import Wizard (/templates/import)



Excel 가져오기 마법사

- **기존 엑셀 자산 변환:** 기존 엑셀 체크리스트 파일을 업로드하고 컬럼(항목코드, 요건명, 질문, 점검기준 등)을 매핑하여 신규 템플릿으로 즉시 변환
- **건드린 행을 짚어 주는 미리보기:** 건너뛴 행, 항목코드를 자동 부여한 행, 길이 제한으로 자른 행을 **행 번호**로 알려 줍니다. 건수만 알려 주면 300행짜리 워크북에서 어느 행인지 찾는 일이 그대로 남습니다

13. 개인 프로필 (/profile)

SecCheck
SECURITY REVIEW

SecCheck
보안성 심의 관리

데모 관리자
정보보호팀

업무

- 대시보드
- 내 심의
- 신규 심의 요청

검토

- 보안 검토 Queue

관리

- 체크리스트 템플릿
- Excel 가져오기
- Rule 시뮬레이터
- Security Controls
- 심의 리포트
- 사용자-역할
- 서비스 설정
- 감사로그
- 서버 로그
- 작업 큐

빠른 이동 Ctrl K

개인 프로필

개인화 설정은 서비스 관리자 설정과 분리되어 있습니다.

기본정보

사용자명

인증 원본

표시 이름

이메일

부서

역할

APPROVER
AUDITOR
REQUESTER
SECURITY_REVIEWER
SYSTEM_ADMIN
TEMPLATE_ADMIN

저장

비밀번호 변경

현재 비밀번호 *

새 비밀번호 *

새 비밀번호 확인 *

12자 이상

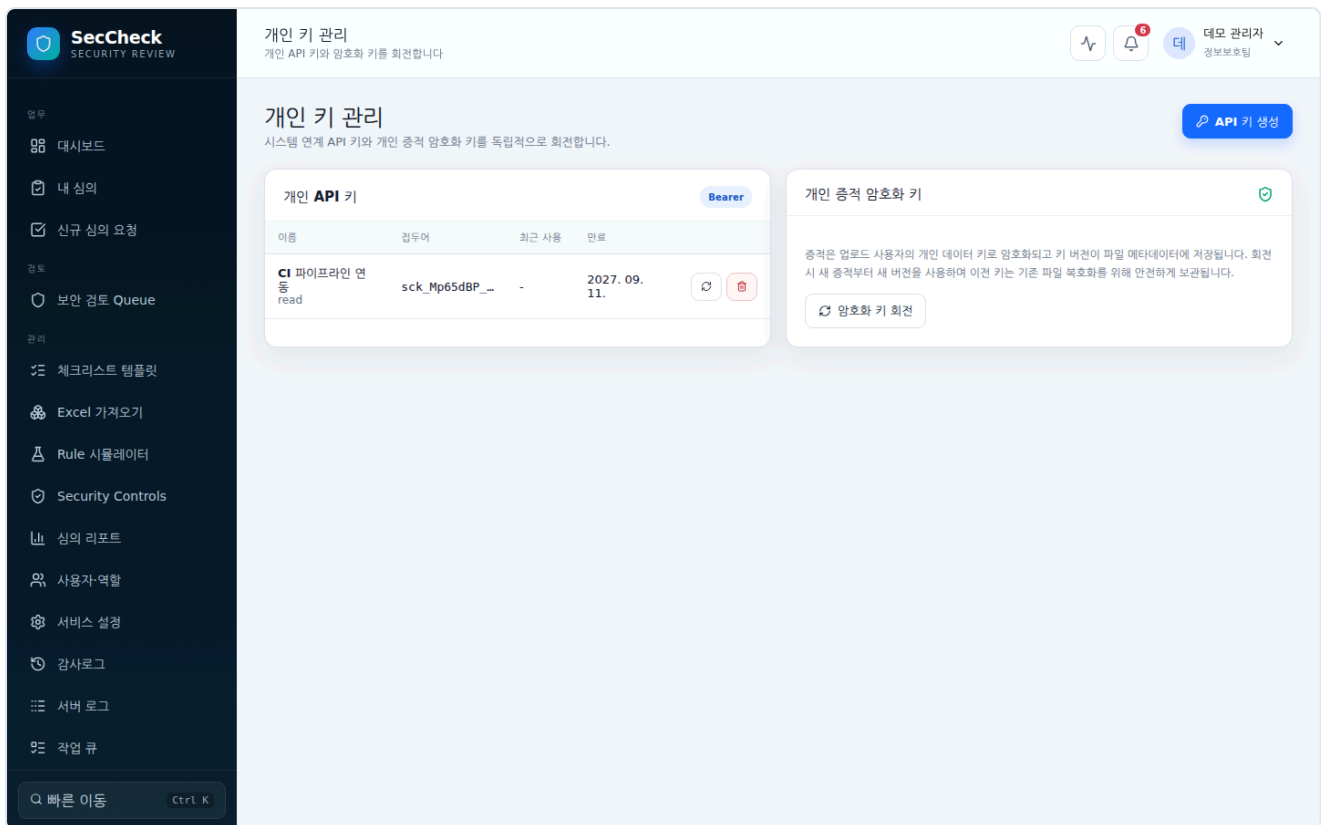
변경하면 현재 사용 중인 브라우저를 제외한 모든 로그인 세션이 즉시 종료되고, 로그인 실패 감금 카운터도 초기화됩니다.

비밀번호 변경

개인 프로필

- 계정 정보: 표시 이름, 이메일, 부서, 인증 원본(로컬/OIDC), 부여된 RBAC 역할 확인 및 정보 변경

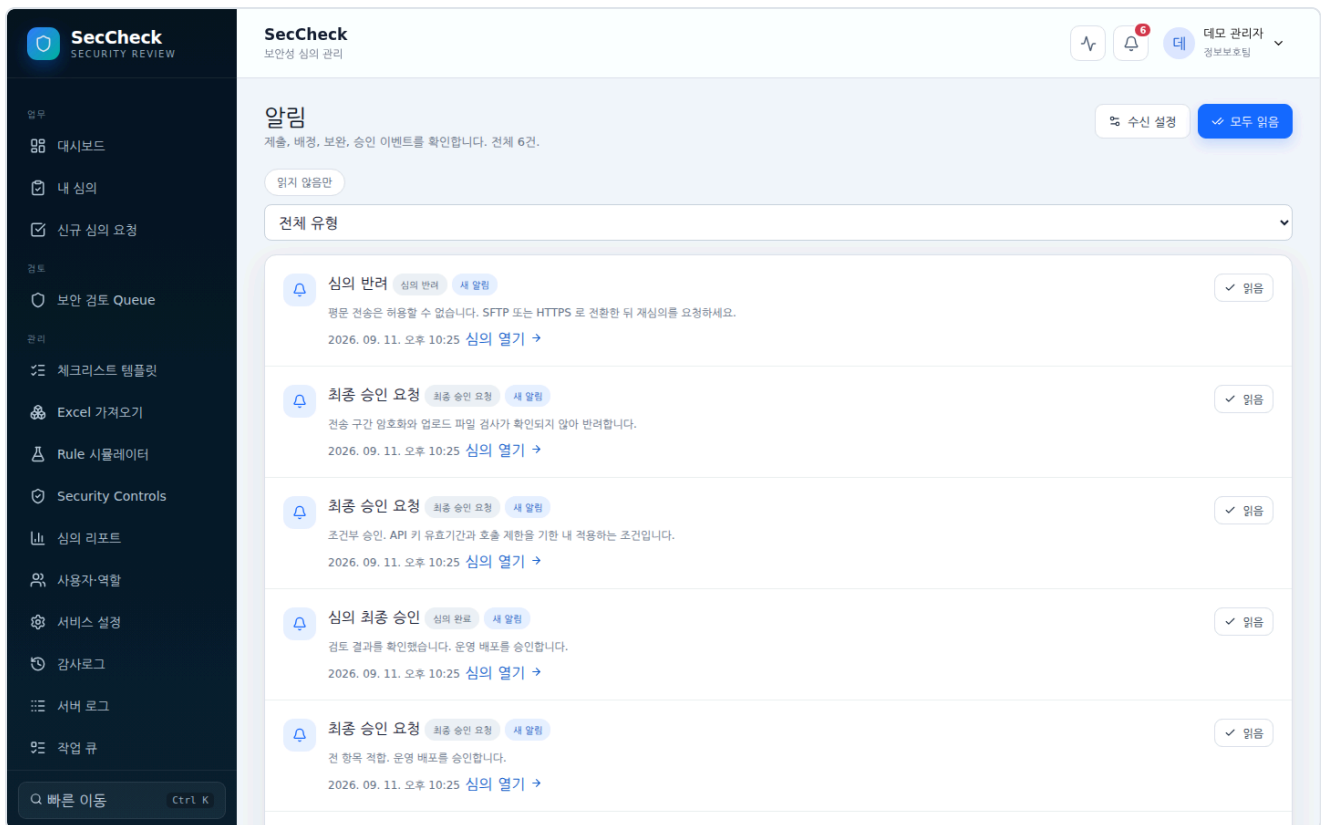
14. 개인 키 관리 & 증적 암호화 키 회전 (/profile/keys)



개인 키 관리

- **개인 Bearer API 키:** 시스템 연동 및 CI/CD 파이프라인용 API 키 발급, 회전 및 폐기
- **API 키 만료 관리:** 목록에 만료일과 만료 임박 · 만료됨 표시를 함께 보여 주고, 만료 7일 전에 발급자에게 API 키 만료 임박 알림을 보냅니다. 키를 쓰는 연동이 예고 없이 401로 끊기지 않도록 합니다.
- **증적 정기 무결성 확인:** 저장된 증적을 매시 20건씩 돌아가며 복호화해 크기·SHA-256을 대조하고, 사라졌거나 달라진 파일을 관리자에게 알립니다.
- **개인 증적 암호화 키 회전 (Zero-Downtime Data Key Rotation):** 개인 암호화 키를 회전하여 새 증적부터 신규 버전을 적용하며, 이전 키는 기존 증적 복호화를 위해 안전 보관

15. 인앱 알림 센터 (/notifications)



알림

- 심의 이벤트 피드: 심의 제출, 검토자 배정, 보완 요청, 승인/반려 알림 열람 및 읽음 처리

16. API · MCP 연계 가이드 (/integrations)

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

API · MCP

보안 자동화와 AI 에이전트 연계를 구성합니다

API · MCP 연계

Security, IT, AI 자동화를 위한 인증된 인터페이스입니다.

OpenAPI 3.1

REST API

Model Context Protocol

브라우저 세션은 CSRF 보호를 사용하고 시스템 연계는 개인 키의 Bearer 인증을 사용합니다. 모든 API가 Backend에서 RBAC와 객체 접근 권한을 다시 검증합니다.

Authorization: Bearer sck_...

curl -H "Authorization: Bearer \$KEY" \ http://127.0.0.1:8080/api/v1/review-requests

명세는 서버의 라우트 등록 테이블에서 생성되므로 모든 엔드포인트가 포함되며, operation마다 필요한 역할이 x-required-roles로 표기됩니다.

명세 열기

최신 Stateless Streamable HTTP를 지원하며, 구형 2025-11-25 initialize 클라이언트도 호환합니다. 개인 API 키를 Authorization 헤더에 설정하세요.

Endpoint

http://127.0.0.1:8080/mcp

제공 도구 (7)

seccheck.dashboard **읽기 전용**
권한 범위의 심의 상태별 건수와 처리할 보안 요청을 조회합니다.

seccheck.get_review **읽기 전용**
심의 ID로 기본정보, 진행률, 상태와 담당자를 조회합니다.

seccheck.list_reviews **읽기 전용**
권한 범위의 보안성 심의를 상태 또는 검색어로 조회합니다.

seccheck.search_controls **읽기 전용**
계시된 체크리스트의 항목 코드, 보안요건, 질문과 가이드를 검색합니다.

seccheck.review_report **읽기 전용**
기간별 심의 처리 현황, 처리 소요 기간, 부서별 집계와 반복 미흡 항목을 조회합니다.

seccheck.my_queue **읽기 전용**
지금 본인이 처리해야 하는 심의와 기한이 임박한 보안 요청을 조회합니다.

seccheck.validate_submission **읽기 전용**
제출 전 서버 검증을 실행하고 누락된 적용여부, N/A 사유, 중격 또는 검사 상태를 반환합니다.

API 및 MCP 연계

- REST API & OpenAPI 3.1: 엔드포인트 명세 및 Bearer 인증 가이드
- Model Context Protocol (MCP): 2026-07-28 Stateless Streamable HTTP 지원 및 5대 도구 연동 안내

17. 서비스 관리자: 사용자 및 역할 관리 (/admin/users)

사용자·역할

RBAC 사용자와 최소 권한을 관리합니다

6

데

데모 관리자

정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자·역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

사용자 및 역할

RBAC 역할을 조합하고 비활성 계정의 세션을 즉시 종료하며, 로그인 실패로 잠긴 계정을 해제하거나 임시 비밀번호를 발급합니다.

Q 이름, 아이디, 이메일, 부서 검색

전체 계정

5 / 5명

사용자	부서	인증	역할	마지막 접속	상태	
김보안 kim · kim@example.com	정보보 호팀	LOCAL	보안 담당자 체크리스트 관리자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할 비밀번호 업무 인계
데모 관리자 admin admin@example.com	정보보 호팀	LOCAL	승인자 감사자 심의 요청자 보안 담당자 시스템 관리자 체크리스트 관리자	2026. 09. 11. 오늘	활성	역할 비밀번호 업무 인계
박감사 park park@example.com	감사실	LOCAL	감사자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할 비밀번호 업무 인계
이승인 lee · lee@example.com	정보보 호팀	LOCAL	승인자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할 비밀번호 업무 인계
홍길동 hong · hong@example.com	플랫폼 개발팀	LOCAL	심의 요청자	기록 없음 · 2026. 09. 11. 생성	활성 임시 비밀번호	역할 비밀번호 업무 인계

사용자 관리

- 업무 일괄 인계:** 떠나는 계정이 맡고 있는 심의·항목·보완 요청의 담당을 한 번에 다른 사람에게 넘깁니다. 넘길 수 없는 자리는 이유와 함께 남겨 둡니다
- RBAC 7대 역할 체계:** SYSTEM_ADMIN , TEMPLATE_ADMIN , SECURITY_REVIEWER , REQUESTER , CONTRIBUTOR , APPROVER , AUDITOR 조합 및 활성화/비활성 즉시 제어
- 마지막 접속과 접근 검토:** 계정별 마지막 로그인 일시와 경과 일수를 표시. 권한 계정이 장기 미접속 관리자 잠금 기준일에 근접하면 경고, 초과하면 잠금 대상 으로 표시하며, N일 이상 미접속 필터로 접근 검토 대상을 한 번에 조회

18. 서비스 관리자: 시스템 설정 (/admin/settings)

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

서비스명

표시 시간대

SecCheck

Asia/Seoul

IANA 이름. 화면-내보내기-요약 메일 시각이 모두 이 시간대로 표시됩니다.

세션 시간(분)

보존 기간(일)

480

1825

서비스 주소

https://seccheck.company.internal

알림 메일의 바보가기 링크에 사용합니다. 비워 두면 링크를 넣지 않습니다. 예: https://seccheck.company.internal

변경 사항은 감사로그에 기록됩니다.

관리자 설정 - 일반

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

Keycloak / OIDC SSO 활성화

Issuer URL

Client ID

https://keycloak.example/realms/company

Client Secret

Callback URL

Keycloak confidential client secret

https://seccheck.example/api/v1/auth/oidc/callback

사용자명 Claim

신규 사용자 기본 역할

preferred_username

REQUESTER

그룹 Claim

그룹 매핑에 해당하지 않는 사용자에게 부여됩니다.

groups

비우면 groups

그룹 → 역할 매핑

+ 매핑 추가

지정하면 로그인할 때마다 IdP 그룹을 기준으로 역할을 다시 맞춥니다. 그룹에서 빠진 사용자는 해당 역할을 잃습니다. 비워 두면 기본 역할만 부여합니다. 시스템 관리자는 매핑할 수 없습니다.

Discovery 연결 테스트

변경 사항은 감사로그에 기록됩니다.

관리자 설정 - OIDC

 **SecCheck**
SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

알림

HTTPS 전용 Secure Cookie

/metrics를 인증 없이 공개

Prometheus 스크램의 일반적인 방식입니다. 고면 사용자 수, 24시간 로그인 실패 수, 잠긴 계정 수 같은 값이 공개되지 않으며, 읽기 범위 API 키로 계속 수집할 수 있습니다.

분당 요청 제한

2000

잠기 미접속 관리자 잠금(일)

90

분당 로그인 실패 제한

30

계정 잠금 실패 횟수

5

IP별 실패 시도만 계산합니다

계정 잠금 시간(분)

15

API 키 최대 유효기간(일)

365

유효 세션 만료(분)

0

0이면 제한 없음. 만료일을 비우고 발급하면 이 기간이 적용됩니다

0이면 세션 시간까지 유지

관리자·검토자·승인자 계정에 일회용 코드(TOTP) 필수

신뢰 Reverse Proxy

관리자 설정 - 보안

SecCheck

SECURITY REVIEW

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

ctrl K

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

18

데

데모 관리자

정보보호팀

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반

검토·승인

Keycloak OIDC

파일 보안

접근 보안

메일

방문 추적

메일 알림 활성화

기본은 꺼짐. 커먼 인접 알림 가운데 아래 스위치가 켜진 종류만 사내 SMTP 릴레이로 보냅니다. 인접 알림은 항상 기록됩니다.

SMTP 호스트

relay.company.internal

사내 릴레이 주소. 패배망이면 postra 를 가리키십시오.

전송 보안

auto (릴레이가 알리는 대로)

auto 는 릴레이가 STARTTLS 를 알리면 쓰고 아니면 평문. 465 포트는 자동으로 tls.

SMTP 사용자

인증 없는 릴레이가 흔하므로 선택 사항

발신 주소

seccheck@company.internal

서비스 주소

https://seccheck.company.internal

메일 속 바르기 링크가 가리킬 이 서비스의 주소. 비워 두면 링크를 넣지 않습니다.

연결 제한 시간(초)

10

SMTP 포트

25

사내 릴레이는 대개 25

TLS 인증서 검증 생략

사내 인증서가 사설일 때만.

SMTP 비밀번호

비워 두면 인증 없이 보냅니다.

발신자 이름

SecCheck

일일 요약 발송 시작

8

0~23시. 요약 수신을 선택한 사용자에게 이 시작 이후 하루 한 번 발송합니다.

보내는 이벤트

사람이 실제로 기다리는 일만 메일이 됩니다. 자기가 한 일은 자기에게 보내지 않고, 요약 수신자에게는 하루 한 통으로 묶습니다. 사용자는 알림 화면의 수신 설정에서 유형별로 더 골 수 있습니다.

내 차례

심의 제출-배정-인계, 항목 배경, 결재 요청, 보완 요청과 조치 완료, 후속조치 이행 보고

결과

심의 승인-반려-취소, 결재 요청 회수, 후속조치 이행 확인

기한

보완-후속조치 기한, 오픈 예정일, API 키 만료 일박, 심의 경계

장애

작업 큐 정체-게시도 소진, 저장 공간, 증적 무결성-악성코드, 감사로그 체인, 계정 잠금

테스트 메일 받는 주소

admin@example.com

테스트 메일 보내기

저장한 설정으로 이 주소에 한 통을 보내고 결과를 아래 기록에 넣습니다. 기본은 내 프로필의 이메일 주소입니다.

메일 발송 기록

릴레이에 넣긴 모든 시도입니다. 본문은 남기지 않습니다. 성공 0 · 실패 0 · 건너뛴 0

아직 보낸 메일이 없습니다.

새로고침

변경 사항은 감사로그에 기록됩니다.

관리자 설정 - 메일

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반 검토·승인 Keycloak OIDC 파일 보안 접근 보안 알림

팀장/승인자 최종 승인 프로세스

본인이 신청한 심의를 본인이 검토·승인 허용

검토자 배경 필수

기본은 금지입니다. 신청자와 검토자가 같은 사람이면 심의의 의미가 없기 때문이며, 담당자가 한 명뿐인 설치에서만 허용합니다.

승인 프로세스가 꺼져 있으면 보안 담당자의 검토 완료가 즉시 최종 심의 완료로 처리됩니다. 켜져 있으면 APPROVAL_PENDING 상태에서 승인자에게 전달됩니다.

변경 사항은 감사로그에 기록됩니다.

관리자 설정 - 워크플로

서비스 관리자 설정

운영 설정과 OIDC를 중앙 관리합니다

데모 관리자
정보보호팀

업무

대시보드

내 심의

신규 심의 요청

검토

보안 검토 Queue

관리

체크리스트 템플릿

Excel 가져오기

Rule 시뮬레이터

Security Controls

심의 리포트

사용자-역할

서비스 설정

감사로그

서버 로그

작업 큐

빠른 이동

Ctrl K

서비스 관리자 설정

환경변수 없이 운영 중 변경 가능하며 비밀값은 ENCRYPTION_KEY로 암호화됩니다.

설정 저장

일반 검토·승인 Keycloak OIDC 파일 보안 접근 보안 알림

최대 파일 크기(MB)

25

허용 확장자

pdf, png, jpg, jpeg, xlsx, xls, docx, zip, txt, json

원프로 구분

ClamAV 악성코드 검사

ClamAV 주소

clamav:3310

연결 테스트

저장 전에 연결을 확인할 수 있습니다.

삭제 중지 보관(일)

90

논리 삭제 후 이 기간이 지나면 암호화된 파일을 볼륨에서 제거합니다. 메타데이터와 감사 기록은 남습니다.

파일은 확장자와 실제 Magic/MIME을 함께 검증한 뒤 UUID 파일명으로 1MB 청크 AES-256-GCM 스트림으로 저장됩니다. 삭제된 종격의 암호문은 보관 기간이 지나면 매시간 유지보수 작업이 볼륨에서 제거하며, 파일명·행사·삭제자 기록은 감사 목적으로 보존됩니다.

변경 사항은 감사로그에 기록됩니다.

관리자 설정 - 파일보안

- **일반 설정:** 세션 시간, 데이터 보존 기간(일), 표시 시간대

- **검토·승인 워크플로**: 팀장/승인자 최종 승인 프로세스 On/Off, 검토자 배정 필수 정책
- **본인 심의 처리 금지**: 신청자 본인은 자신이 올린 심의를 검토하거나 승인할 수 없습니다(기본값). 담당자가 한 명뿐인 설치를 위해 설정에서 해제할 수 있습니다
- **Keycloak OIDC SSO**: Issuer Discovery, Client Secret(암호화 보관), 그룹 → 역할 매핑(로그인마다 동기화, 그룹에서 빠지면 역할 회수), 연결 테스트. IdP 세션이 있으면 자동 로그인 을 켜면 Keycloak 에 이미 로그인한 사람은 로그인 화면 없이 바로 들어오고, 세션이 없는 사람은 로그인 화면을 한 번만 봅니다(루프 없음)
- **파일 보안 & ClamAV**: 최대 파일 크기, 허용 확장자 화이트리스트, ClamAV 데몬 주소 및 악성코드 차단
- **접근 보안**: HTTPS Secure Cookie, Rate Limiting, 장기 미접속 관리자 잠금, CORS Origin
- **메일 (SMTP 릴레이)**: 호스트, 포트, 전송 보안(auto / none / starttls / tls), 인증(선택), 발신 주소·이름, 서비스 주소, 일일 요약 발송 시각. 보내는 이벤트는 내 차례 · 결과 · 기한 · 장애 네 묶음 스위치로 고르고, 본인이 한 일의 알림은 본인에게 보내지 않습니다. 테스트 메일 보내기 와 시도마다 남는 발송 기록(성공·실패·건너뛸, 본문 없음)을 같은 탭에서 봅니다
- **방문 추적**: 어떤 화면이 쓰이는지 세는 스크립트(Momento 사내 수집기 우선, GA4·GTM·Matomo·직접 입력)를 화면에서 붙입니다. 요청마다 nonce 를 발급해 Content-Security-Policy 를 'unsafe-inline' 없이 유지하고, 정책이 차단한 출처를 표로 보여 허용 한 번으로 더할 수 있습니다

19. 서비스 관리자: 해시 체인 불변 감사로그 (/admin/audit)

감사로그
중요 행위의 해시 체인 이력을 확인합니다

감사로그
이전 이벤트를 연결한 위변조 탐지 체인입니다. 애플리케이션에서 수정·삭제 API를 제공하지 않습니다.

이벤트 유형: (일부만 입력해도 됩니다. 예: LOGIN)

대상 ID: (표의 대상 값을 누르면 그 대상의 이력이 남습니다.)

결과: (거부된 시도만 모아 봅니다.)

시작일: (필터 초기화)

사용자 / 접속 IP:

이벤트 ID: (무결성 실패 알림이 가리키는 그 이벤트만 봅니다.)

시작일:

표시 건수:

시간	이벤트	사용자 / IP	대상	결과	해시
2026. 09. 11. 오후 10:26	심의 조회 VIEW_SUBMISSION	데모 관리자 127.0.0.1	REVIEW_REQUEST 7a14d6aa-fd0c-4e6f-a844-171095237aab	SUCCESS	8c456ba11668...
2026. 09. 11. 오후 10:26	심의 조회 VIEW_SUBMISSION	데모 관리자 127.0.0.1	REVIEW_REQUEST 3b1a2819-debd-4a36-93e1-42416c454564	SUCCESS	14e26e197722...
2026. 09. 11. 오후 10:25	심의 조회 VIEW_SUBMISSION	데모 관리자 127.0.0.1	REVIEW_REQUEST 27aeb58a-2174-4d71-8725-74e7d5c4fc6d	SUCCESS	8391a7898a4a...

감사로그

- **암호학적 해시 체인 (Hash Chaining)**: 이전 이벤트 해시(prev_hash)를 연결하여 위변조를 원천 차단
- **원클릭 체인 검증 (체인 검증)**: 전체 감사 이벤트의 무결성을 실시간으로 검증

20. 서비스 관리자: 구조화 서버 로그 (/admin/logs)

서버 로그

민감정보를 제외한 구조화된 운영 로그와 요청 ID를 확인합니다. 검색은 메시지, 구성요소, 요청 ID와 필드를 함께 조회합니다.

Q 메시지, 구성요소, 요청 ID, 경로 검색

전체 레벨

10초 자동 새로고침

시간	레벨	구성요소	메시지
2026. 09. 11. 오후 10:26	INFO	http	HTTP request {"duration_ms":1,"method":"GET","path":"/api/v1/notifications/unread-count","status":200}
2026. 09. 11. 오후 10:26	INFO	http	HTTP request {"duration_ms":3,"method":"GET","path":"/api/v1/me","status":200}
2026. 09. 11. 오후 10:26	INFO	http	HTTP request {"duration_ms":1,"method":"GET","path":"/api/v1/public/config","status":200}
2026. 09. 11. 오후 10:26	INFO	http	HTTP request {"duration_ms":3,"method":"GET","path":"/api/v1/admin/audit","status":200}
2026. 09. 11. 오후 10:26	INFO	http	HTTP request {"duration_ms":2,"method":"GET","path":"/api/v1/notifications/unread-count","status":200}
2026. 09. 11. 오후 10:26	INFO	http	HTTP request {"duration_ms":2,"method":"GET","path":"/api/v1/me","status":200}

서버 로그

- 민감정보 마스킹 구조화 로그: 요청 ID(Request ID), 레벨(INFO/WARN/ERROR), 구성요소별 로그 실시간 조회

21. 심의 리포트 (/reports)

- 기간·부서별 집계: 시작일/종료일과 부서로 좁혀 신규·완료·진행 중·반려 건수를 한 번에 확인. 이번 달 · 최근 3개월 · 최근 1년 프리셋 제공
- 처리 기간 지표: 제출부터 최종 승인까지 걸린 일수의 평균·중앙값·90분위. 완료 건이 없으면 지표 대신 안내를 표시
- 반복 미흡·부적합 항목: 같은 항목코드에서 반복 지적된 보안요건을 발생 건수 순으로 집계해 교육·표준화 대상을 도출
- 같은 서비스에서 반복된 지적: 한 서비스가 같은 체크리스트 항목을 두 번 이상 미흡·부적합으로 받은 조합을 지적 횟수·마지막 판정일과 함께 표시합니다. 통제별 집계가 가리는 "재발"을 드러내며, Excel 반복 지적 서비스 시트로도 내려받습니다
- 미초치 항목: 검토자가 판정과 함께 남긴 조치 사항과 조치 기한 을 심의 전체에서 모아 표시. 기한 7일 전과 초과 시 심의 요청자에게 알림 발송(항목당 주 1회). 기한이 지난 건은 기한 초과 로 구분하고 목록 상단에 배치. 조치 담당자가 항목에서 조치 완료 보고 로 조치 내용을 남기고 보안 담당자가 리포트에서 이행 확인 으로 종료하며, 종료된 항목은 기본 목록에서 빠지고 이행 완료 포함 으로 다시 볼 수 있음. 심의가 취소된 건의 조치도 기본 목록에서 빠집니다(아무도 이행할 수 없는 약속이므로 미이행 집계에 넣지 않습니다). 이행 완료 포함 으로 보면 심의

취소됨 표시와 함께 그대로 남아 있고, Excel 미조치 항목 시트에는 심의 상태 열이 있습니다. 이행과 해제는 모두 감사로그에 기록. 이행 확인과 해제는 그 심의의 담당 검토자만 할 수 있음(등록부에 확인자 이름이 남으므로, 본 적 없는 서비스의 조치를 종결할 수 없어야 함). 다만 담당 검토자가 비활성화되었거나 검토자 역할을 잃으면 아무도 달을 수 없게 되므로 그때는 다른 보안 담당자가 대신 처리할 수 있고, 처리 권한이 없는 행은 등록부에서 담당 검토자만 처리 로 표시됨. 조건부 적합처럼 "나중에 하기로 한 것"은 지금까지 해당 심의 안에서만 보였으므로, 팀 전체의 미이행 약속을 한눈에 보기 어려웠음. 심의번호·서비스·항목·판정·조치 내용·판정일을 최근 판정순으로 최대 500건 심의번호를 누르면 해당 심의로 바로 이동하고, 상태별 · 부서별 표의 값도 같은 기간 조건으로 심의 목록을 엽니다.

- 진행 중 심의 경과(Aging): 마지막 변경 이후 경과 구간별 건수로 정제된 심의를 식별
- Excel 리포트: 화면과 동일한 조건으로 요약·상태별·부서별·판정별·반복 지적·경과 6개 시트 워크북을 내려받기
- 접근 권한: SYSTEM_ADMIN , SECURITY_REVIEWER , AUDITOR , APPROVER

22. Rule Engine 시뮬레이터 (/templates/rules)

- 심의를 만들지 않는 사전 검증: 서비스 유형·변경 유형·노출 범위·중요도만 입력하면 어떤 체크리스트가 배정되는 지 즉시 확인
- 템플릿별 배정 결과: 매칭된 템플릿과 항목 수, 그리고 각 항목이 배정/제외된 이유를 규칙 단위로 표시
- 신청자용 사전 확인: 신규 심의 요청 화면에서도 같은 시뮬레이션으로 배정될 항목 목록과 증적이 필요한 항목 수를 심의 생성 전에 확인합니다
- 조건 단위 설명: 항목마다 규칙의 조건을 한 줄씩 펼쳐 이 서비스에서 만족되는지(✓ / ✕)와 규칙이 요구하는 값 대 현재 값을 함께 보여 줍니다(✕ 노출 구분 = EXTERNAL — 현재 INTERNAL). 설명은 규칙 엔진이 실제로 내린 판정을 그대로 옮기므로 규칙과 설명이 어긋날 수 없습니다
- 게시 전 검증 목적: 게시된 버전은 수정할 수 없으므로, 규칙을 확정하기 전에 이 화면에서 결과를 맞춰본 뒤 게시
- 접근 권한: TEMPLATE_ADMIN , SECURITY_REVIEWER (신청자는 신규 심의 요청 화면에서 자신의 입력에 대한 미리보기를 확인)

23. 서비스 관리자: 작업 큐 (/admin/jobs)

- 백그라운드 작업 가시화: 이메일 알림 발송과 증적 악성코드 검사는 큐에서 비동기로 처리되며, 유형·상태·시도 횟수·다음 실행 시각을 조회
 - 마지막 오류 확인: 실패한 작업의 오류 메시지를 그대로 노출해 SMTP·ClamAV 설정 문제를 즉시 진단
 - 정체 감지: 워커는 5초마다 큐를 확인하므로, 실행 시각이 지난 작업이 5분 넘게 남아 있으면 워커가 멈춘 것으로 보고 경고를 표시. 재시도 대기(backoff) 중인 작업은 정체로 세지 않음
 - 정체 알림: 15분 넘게 정체되면 유지보수 워커가 시스템 관리자에게 인앱 알림을 발송(이메일 워커 자체가 멈춘 상황이므로 인앱만 신뢰 가능). 같은 장애로는 6시간에 한 번만 알림
 - 수동 재시도: 원인을 고친 뒤 재시도 로 대기 상태로 되돌려 다음 워커 주기에 다시 실행
 - 접근 권한: SYSTEM_ADMIN
-

24. 서비스 관리자: API 키 (/admin/api-keys)

- **설치 전체의 기계 자격증명:** 소유자, 키 이름과 접두사, 범위(read / read:write), 마지막 사용 시각, 만료일을 한 화면에서 확인합니다. 지금까지 API 키는 발급한 본인에게만 보였기 때문에, 접근 권한 검토가 가장 먼저 묻는 "어떤 비인간 자격증명이 있는가"에 답할 방법이 없었습니다
 - **상태 구분:** 사용 가능 · 폐기됨 · 만료 · 계정 비활성 . 계정을 비활성화하면 그 계정의 키는 폐기하지 않아도 인증이 거부됩니다
 - **폐기:** 다른 사용자의 키도 폐기할 수 있으며, 감사로그(REVOKE_API_KEY)에 남고 소유자에게 알림이 갑니다. 이유 없이 멈춘 연동을 디버깅하게 두지 않기 위해서입니다
 - **기본 화면은** 사용 가능한 키만 보여 주고, 선택을 바꾸면 폐기·만료된 키까지 봅니다
 - **접근 권한:** SYSTEM_ADMIN
-

25. 서비스 관리자: 시스템 정보 (/admin/system)

- **업그레이드 확인:** 실행 중인 버전, 적용된 스키마 버전, Go 런타임, 서버 시각을 한 화면에서 확인
 - **역할 보유자:** 역할별 활성 계정 수. 보유자가 없으면 담당자 없음 , 한 명뿐이면 1명뿐 으로 표시합니다. 본인 심의 는 본인이 검토·승인할 수 없으므로 검토자·승인자가 한 명뿐이면 그 사람의 신청 건이 막힙니다
 - **증적 저장소:** 볼륨 경로, 쓰기 가능 여부, 남은 공간과 비율. 여유가 10% 아래로 떨어지거나 쓸 수 없게 되면 시스템 관리자에게 알림이 발송되며, 이 화면에서 먼저 확인할 수 있습니다
 - **PDF 내보내기 가능 여부:** 한글 글꼴이 image에 포함되어 있는지 표시. 사용자가 내보내기에 실패하기 전에 알 수 있습니다
 - **데이터 규모:** 사용자·심의·템플릿·증적·서버 로그 건수와 데이터베이스 크기
 - **접근 권한:** SYSTEM_ADMIN
-

26. 계정 보안 (/profile/security)

- **일회용 코드(TOTP) 등록:** QR 코드와 수동 입력용 시크릿을 제공하고, 인증 앱의 코드를 한 번 검증해야 활성화. RFC 6238 표준 준수
- **관리자 강제 적용:** 시스템 설정에서 2단계 인증을 필수로 지정하면 미등록 사용자는 로그인 직후 이 화면으로 유도 되어 등록 전까지 다른 기능을 사용할 수 없음
- **로그인 세션 관리:** 접속 중인 세션의 브라우저·IP·마지막 활동 시각을 확인하고, 현재 세션을 제외한 다른 세션을 개별 또는 일괄 종료

SecCheck API & MCP 연계 가이드 (API & MCP Guide)

SecCheck 는 시스템 연계 및 CI/CD 자동화를 위한 REST API와 AI 에이전트(Claude Desktop, Cursor 등) 연동을 위한 Model Context Protocol (MCP) 인터페이스를 제공합니다.

1. 인증 체계 (Authentication)

모든 API 및 MCP 호출은 개인 키 관리(/profile/keys)에서 발급받은 **Bearer API Key** 또는 세션 쿠키를 사용합니다:

```
Authorization: Bearer sck_a1b2c3d4_XXXXXXXXXXXXXXXXXXXXXXXXXXXX
```

1-1. OpenAPI 명세

전체 API 명세는 로그인 상태에서 GET /api/openapi.json 으로 받습니다. 명세는 서버의 라우트 등록 테이블에서 생성되므로 문서화되지 않은 엔드포인트가 존재할 수 없습니다. 각 operation에는 다음이 포함됩니다.

- `summary` · `tags` — 한글 설명과 기능 분류
- `operationId` — 메서드와 경로에서 파생된 안정적인 식별자 (클라이언트 자동 생성용)
- `parameters` — 경로 파라미터 선언
- `requestBody` — 본문을 받는 operation의 JSON 속성과 타입. 서버가 알 수 없는 속성을 거부하므로 스키마도 `additionalProperties: false` 입니다. 즉 명세대로 보내면 그대로 통과합니다
- `x-object-scoped` — `true` 이면 역할이 아니라 **대상 심의에 대한 접근 권한**으로 판단합니다. 요청자·공동 작성자·지정된 검토자·승인자가 해당하며, 조회는 `SECURITY_REVIEWER` 와 `AUDITOR` 도 모든 심의에 접근합니다.
`SYSTEM_ADMIN` 은 포함되지 않습니다 — 서비스 운영 권한이 남의 심의 열람 권한은 아닙니다. 권한이 없으면 404이므로, 역할만 보고 호출 가능 여부를 판단하면 안 됩니다
- `x-required-roles` — 호출에 필요한 RBAC 역할. 빈 배열이면 로그인한 모든 사용자가 호출 가능
- `security: []` — 인증 없이 호출 가능한 엔드포인트 (/api/v1/auth/login , /api/v1/public/config 등)

아래 표는 자주 쓰는 엔드포인트만 추린 것이며, 전체 목록은 명세를 참조하십시오.

2. REST API 주요 엔드포인트 (/api/v1)

심의 요청 및 관리 (Review Requests)

메서드	경로	설명	권한
GET	/review-requests	심의 목록 조회 (필터: q , status)	전체 (권한 범위의 심의만 반환)
POST	/review-requests	신규 심의 생성 및 Rule Engine 자동 배정	REQUESTER
GET	/review-requests/{id}	심의 상세 정보 및 진행 통계 조회	담당자, 검토자, 승인자
GET	/review-requests/{id}/items	심의에 배정된 체크리스트 항목 및 답변 목록	담당자, 검토자, 승인자
PUT	/review-requests/{id}/responses/{itemID}	체크리스트 항목 작성 및 자동 저장	해당 심의 참여자
GET	/review-requests/{id}/submission-check	제출을 막는 미완료 항목 목록 (ready , issues). 제출 전에 미리 확인	담당자, 검토자, 승인자
GET	/review-requests/{id}/completion-check	검토 완료를 막는 항목 목록 (ready , issues). 검토자용	담당자, 검토자, 승인자
GET	/review-requests/{id}/assignees	항목 담당자로 지정할 수 있는 사용자 목록	담당자, 검토자, 승인자
GET	/review-requests/{id}/items/{itemID}/verdict-history	같은 서비스의 이전 심의에서 이 항목이 받은 판정	담당자, 검토자, 승인자
POST	/review-requests/{id}/transfer-requester	심의 요청자를 다른 사람에게 인계	요청자 본인 또는 시스템 관리자
POST	/review-requests/{id}/submit	심의 제출 (서버 검증 실행)	해당 심의 참여자
POST	/review-requests/{id}/begin-review	보안 검토 시작 (REVIEWING 전환)	SECURITY_REVIEWER
PUT	/review-requests/{id}/review-results/{itemID}	항목별 검토 결과 및 의견 저장	SECURITY_REVIEWER
POST	/review-requests/{id}/approve	심의 최종 승인	APPROVER

메서드	경로	설명	권한
POST	/review-requests/{id}/reject	심의 반려	APPROVER
POST	/review-requests/{id}/reopen	반려 심의 보완 재개(보완 필요 로 되돌림)	SECURITY_REVIEWER
POST	/review-requests/{id}/withdraw-approval	결재 요청 회수(검토 중 으 로 되돌림)	SECURITY_REVIEWER

증거 파일 (Evidences)

메서드	경로	설명	권한
POST	/review-requests/{id}/items/{itemID}/evidences	증거 파일 암호화 업로드 (multipart/form-data)	해당 심의 참여자
GET	/evidences/{id}/download	증거 파일 복호화 다운로드	권한자
POST	/evidences/{id}/versions	증거 파일 신규 버전 교체 등록	해당 심의 참여자

통합 Security Controls & 템플릿

메서드	경로	설명	권한
POST	/review-requests/{id}/change-requests/bulk	선택 항목 일괄 보완 요청	SECURITY_REVIEWER
POST	/admin/settings/upload/test	ClamAV(clamd) 연결 테스트	SYSTEM_ADMIN
POST	/admin/settings/mail/test	저장된 메일 설정으로 본인(또는 recipient)에게 테스트 메일 1통을 그 자리에서 발송. 결과는 발송 기록에도 남음	SYSTEM_ADMIN
GET	/admin/mail/deliveries	메일 발송 기록. 시도마다 event, recipient, subject, status (SENT · FAILED · SKIPPED), attempt, error. 본문은 없음. status, limit, offset	SYSTEM_ADMIN
GET	/admin/users/{id}/open-work	계정이 아직 닫고 있는 진행 중 심의·미이행 후속조치 수	SYSTEM_ADMIN
GET	/admin/api-keys	설치 전체의 API 키와 소유자·마지막 사용 시각	SYSTEM_ADMIN
POST	/admin/api-keys/{id}/revoke	다른 사용자의 API 키 폐기	SYSTEM_ADMIN
GET	/admin/analytics/violations	방문 추적이 켜진 뒤 콘텐츠 보안 정책이 차단한 출처 목록(origin, directive, page, count, allowed)	SYSTEM_ADMIN
DELETE	/admin/analytics/violations	차단된 출처 목록 비우기	SYSTEM_ADMIN
POST	/admin/analytics/allow	차단된 출처 하나(origin)를 방문 추적 설정의 allowed_hosts 에 추가	SYSTEM_ADMIN
POST	/api/v1/analytics/csp-report	브라우저의 콘텐츠 보안 정책 위반 신고 (application/csp-report). 방문 추적이 켜진 동안만 기록하며 항상 204	없음
GET	/security-controls	통합 Security Control 목록 및 영향 통계	전체
GET	/security-controls/{id}/impact	연결된 체크리스트와 영향 심의 범위, 그리고 이 Control의 판정 이력({items, outcomes})	
GET	/templates	체크리스트 템플릿 목록 및 게시 버전 조회	전체

메서드	경로	설명	권한
GET	/templates/{id}/rule-check	게시된 체크리스트에서 심의에 쓸 수 없는 항목(규칙 오류로 배정되지 않거나, 선택지가 없어 답할 수 없는 항목)	TEMPLATE_ADMIN , SECURITY_REVIEWER

2-1. 오류 응답과 코드

실패 응답은 모두 같은 형태입니다. 연계 스크립트는 HTTP 상태보다 `error.code` 로 분기하십시오. 문구(`message`)는 사용자에게 보여 주기 위한 것이라 릴리즈마다 다듬어지지만, **코드는 계약**입니다.

```
{ "error": { "code": "REVIEW_INCOMPLETE", "message": "미검토 항목 2건이 남아 검토를 완료할 수 없습니다.", "
```

`details` 는 코드마다 다르며 없을 수도 있습니다(`null`).

인증·권한

코드	뜻
AUTHENTICATION_REQUIRED	세션이나 API 키가 없습니다
SESSION_REQUIRED	이 작업은 브라우저 세션에서만 가능합니다
INVALID_CREDENTIALS	아이디 또는 비밀번호가 틀렸습니다
LOGIN_RATE_LIMITED	로그인 시도가 제한 횟수를 넘었습니다
ACCOUNT_LOCKED	로그인 실패가 누적되어 잠긴 계정입니다
TOTP_REQUIRED / TOTP_INVALID / TOTP_FAILED	2단계 인증 코드가 필요·불일치·처리 실패
TOTP_ENROLLMENT_REQUIRED	정책상 2단계 인증 등록이 먼저 필요합니다
PASSWORD_CHANGE_REQUIRED	관리자가 발급한 임시 비밀번호입니다. 본인이 변경해야 다른 요청이 허용됩니다(API 키에는 적용되지 않음)
LAST_PUBLISHED_VERSION	사용 중인 템플릿의 마지막 게시 버전은 중지할 수 없습니다. 새 버전을 게시하거나 템플릿을 사용 안 함으로 바꾼 뒤 중지하세요
API_KEY_LIFETIME	요청한 만료일이 설치에 설정된 API 키 최대 유효기간을 넘습니다
INVALID_RULE	적용 규칙에 오류가 있는 항목이 있어 버전을 게시할 수 없습니다. details 에 항목과 사유가 담깁니다
CSRF_INVALID	CSRF 토큰이 없거나 일치하지 않습니다
RATE_LIMITED	요청 빈도 제한을 넘었습니다
API_SCOPE_FORBIDDEN	API 키의 scope로는 허용되지 않는 작업입니다
FORBIDDEN	권한이 없거나 대상 심의에 참여하지 않습니다
SELF_REVIEW_FORBIDDEN	본인이 신청한 심의는 본인이 검토·승인할 수 없습니다
SELF_APPROVAL_FORBIDDEN	본인이 검토·판정한 심의는 본인이 최종 승인할 수 없습니다
SESSION_SWEEP_FAILED	자격 증명은 바뀌었으나 이 계정의 로그인 세션을 종료하지 못했습니다(다시 시도하십시오)
EXTERNAL_ACCOUNT	외부(OIDC) 계정에는 적용할 수 없는 작업입니다
SELF_LOCKOUT / LAST_ADMIN_PROTECTION	자기 계정 비활성화·관리자 역할 제거는 막습니다
CURRENT_SESSION	지금 사용 중인 세션은 종료 대상에서 제외됩니다

요청 내용

코드	뜻
INVALID_JSON	본문을 JSON으로 읽을 수 없습니다
VALIDATION_FAILED	필드 값이 규칙에 맞지 않습니다(details 에 필드별 사유)
NA_REASON_REQUIRED	N/A 선택 시 사유가 필요합니다
DUE_DATE_REQUIRED / FOLLOW_UP_DUE_REQUIRED	보완 요청·후속조치에는 기한이 필요합니다
REASON_REQUIRED	제출한 심의를 취소하려면 사유가 필요합니다(검토자·승인자에게 전달됩니다)
WEAK_PASSWORD	비밀번호가 정책에 맞지 않습니다(12자 이상, 혼한 비밀번호·아이디·서비스 이름·같은 문자 반복·연속 문자 불가). details 에 사유가 담깁니다
NOT_FOUND	대상이 없거나 접근 범위 밖입니다
FORMAT_NOT_SUPPORTED	지원하지 않는 내보내기 형식입니다
UPLOAD_REJECTED	확장자·크기·MIME 검증에 걸렸습니다
DUPLICATE_ITEM_CODE	같은 버전에 같은 항목코드가 이미 있습니다
NOT_A_PARTICIPANT	심의에 참여하지 않는 사용자에게는 배정할 수 없습니다

상태 충돌 (409·422)

코드	뜻
STATE_CONFLICT	현재 상태에서 허용되지 않는 전이입니다
SUBMISSION_INCOMPLETE	제출 전 검증에 걸렸습니다(details 에 항목별 사유)
REVIEW_INCOMPLETE	미검토 항목·미검증 보완 요청·판정 후 변경 항목이 남았습니다
RESPONSE_CONFLICT / REVIEW_RESULT_CONFLICT	다른 사용자가 먼저 저장했습니다(최신 값이 details 에)
ALREADY_ASSIGNED / ITEM_ALREADY_USED	이미 배정·사용 중이라 다시 적용할 수 없습니다
IMMUTABLE_VERSION	게시된 템플릿 버전은 수정할 수 없습니다
EMPTY_VERSION	항목이 없는 버전은 게시할 수 없습니다
TEMPLATE_IN_USE / CONTROL_IN_USE	사용 중이라 삭제할 수 없습니다
SCAN_NOT_CLEARED	악성코드 검사가 끝나지 않은 증적입니다
EVIDENCE_PURGED	보존기간이 지나 파기된 증적입니다
VERIFY_IN_PROGRESS	같은 검증이 이미 실행 중입니다

서버·인프라 (5xx)

코드	뜻
QUERY_FAILED / SEARCH_FAILED	데이터베이스 조회에 실패했습니다
CREATE_FAILED / UPDATE_FAILED / DELETE_FAILED / COPY_FAILED	저장에 실패했습니다
SUBMIT_FAILED / SNAPSHOT_FAILED	제출·스냅샷 처리에 실패했습니다
UPLOAD_FAILED / STORAGE_FAILED	증적 저장에 실패했습니다
KEY_UNAVAILABLE / ENCRYPTION_FAILED / ROTATE_FAILED	암호화 키를 쓸 수 없습니다
EXPORT_FAILED / FONT_MISSING	내보내기에 실패했습니다(PDF는 한글 폰트 필요)
IMPORT_FAILED / DIFF_FAILED	Excel 가져오기·버전 비교에 실패했습니다
VERIFY_FAILED	감사 체인 검증을 수행하지 못했습니다
SMTP_FAILED / OIDC_DISCOVERY_FAILED / OIDC_INVALID / CLAMAV_FAILED	외부 연동 설정 확인에 실패했습니다
NOT_READY	데이터베이스에 연결할 수 없어 지표·준비 상태를 제공할 수 없습니다

3. Model Context Protocol (MCP) 엔드포인트

- **엔드포인트**: POST /mcp
- **프로토콜 버전**: MCP 2026-07-28 Stateless Streamable HTTP (구형 2025-11-25 호환)
- **인증**: Authorization: Bearer <API_KEY>

 제공 도구 목록 (Tools)

1. seccheck.dashboard : 대시보드 통계 및 긴급 처리 건수 조회
2. seccheck.list_reviews : 상태 및 키워드 기반 심의 목록 검색
3. seccheck.get_review : 특정 심의의 상세 정보, 진행률, 체크리스트 항목 조회
4. seccheck.search_controls : Security Control 및 체크리스트 가이드 검색
5. seccheck.validate_submission : 제출 전 누락 항목 및 결함 사전 검증
6. seccheck.my_queue : 지금 본인이 처리해야 하는 심의와 기한이 임박한 보완 요청 조회
7. seccheck.review_report : 기간별 처리 현황·소요 기간·부서별 집계·반복 미흡 항목 조회 (SYSTEM_ADMIN , SECURITY_REVIEWER , AUDITOR , APPROVER)

도구는 모두 호출자의 권한 범위 안에서만 답합니다. 읽기 전용이 아닌 도구를 API 키로 호출하려면 키에 쓰기 범위가 있어야 하며, 전체 목록과 입력 스키마는 tools/list 로 확인합니다.

💬 MCP 호출 예시 (JSON-RPC 2.0)

요청: 심의 제출 전 결함 사전 검증

```
{
  "jsonrpc": "2.0",
  "id": "req-201",
  "method": "tools/call",
  "params": {
    "name": "seccheck.validate_submission",
    "arguments": {
      "review_id": "9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d"
    }
  }
}
```

응답

```
{
  "jsonrpc": "2.0",
  "id": "req-201",
  "result": {
    "content": [
      {
        "type": "text",
        "text": "검증 결과: 제출 가능한 상태입니다. (작성 완료: 45/45, 필수 증적 첨부: 12건)"
      }
    ]
  }
}
```

SecCheck 시스템 아키텍처 및 보안 설계 (Architecture)

SecCheck 는 오프라인 폐쇄망에서 단일 바이너리와 PostgreSQL만으로 영구 지속되는 안정성을 보장하도록 설계되었습니다.

1. 시스템 아키텍처 다이어그램



2. 핵심 보안 및 설계 불변 원칙

1. 템플릿-버전-스냅샷 3계층 분리 불변 모델

- **Template:** 체크리스트의 최상위 컨테이너
- **Version:** 게시(`PUBLISHED`) 시점의 불변 체크리스트 버전
- **Snapshot (Review Items):** 심의 생성 시점에 배정된 항목들은 템플릿 원본이 추후 변경되더라도 결코 바뀌지 않는 독립 스냅샷으로 영구 보존됩니다.

2. 증거 파일 암호화 파이프라인 (Evidence Encryption)

1. **Magic/MIME 교차 검증:** 파일의 실제 바이트 헤더를 검사하여 확장자 변조 방지

2. SHA-256 해시 계산: 무결성 검증을 위한 해시 생성

3. AES-256-GCM 봉투 암호화: 사용자의 개인 데이터 키(`user_data_keys`)로 암호화 후 디스크에 UUID로 저장

4. 무중단 키 회전: 개인 암호화 키를 회전해도 이전 버전 증거는 계속 안전하게 복호화 지원

3. 암호학적 해시 체인 감사로그 (Cryptographic Hash Chaining)

- 모든 행위는 `SHA256(prev_hash + event_id + timestamp + actor + payload)` 형식으로 연결되어 저장됩니다.
- DB 직접 변조 시 체인이 즉시 파손되어 무결성 검증 단계에서 적발됩니다.